

Deadbolt

Autonomous entitlement drift detection and brokered revocation across SaaS estates

Karthik / SimplifyNext IGNITE Agentic AI Hackathon 2026

Product Requirements Document, v0.1 / 30 August 2026

Contents

1. Problem	2
1.1 Why existing tooling leaves a gap	2
1.2 Who it serves	2
2. Goals and non-goals	2
2.1 Goals	2
2.2 Non-goals (explicit, for the 8-day window)	3
2.3 Alignment risk against the stated brief	3
3. Success metrics	3
4. Architecture	3
4.1 Determinism boundary	3
4.2 Component diagram	4
4.3 Connector strategy	4
4.4 Data model (DynamoDB single table, on-demand)	5
4.5 Risk scoring	5
4.6 Policy tiers and the safety asymmetry	5
4.7 Approval brokering (“the negotiator”)	6
4.8 Execution and rollback	6
5. Tech stack and cost model	6
5.1 Services	6
5.2 Budget	7
5.3 Cost guardrail to build on day 1	7
6. Scope for the 8-day window	7
MUST (submission fails without these)	7
SHOULD	7
WON’T (this cycle)	7
Day plan	7
7. Demo script (5 minutes)	8
8. Risks	8
9. Open questions	9

Field	Value
Version	0.1 (draft)
Owner	Karthik
Event	SimplifyNext IGNITE Agentic AI Hackathon 2026 — Software AI track
Submission deadline	7 Sep 2026
Semi-finals	9-11 Sep 2026 · Grand finale 18 Sep 2026 (NUS)
Infra	AWS Innovation Sandbox, us-east-1, US\$20 hard budget
Status	Pre-build

1. Problem

An employee moves from Backend Engineer to Engineering Manager. HR updates Workday. SSO keeps working. Nothing else changes.

Six months later that person holds: AdministratorAccess on a staging AWS account they no longer deploy to, admin on four GitHub repos they no longer commit to, a fine-grained PAT with repo:write that has not been used since March, Salesforce field-level access to a customer PII object, and a Notion workspace owner seat. None of it was granted maliciously. All of it was granted correctly, once, for a job that no longer exists.

Two failure classes follow:

1. **Privilege creep on movers.** Entitlements accumulate monotonically because grant is a one-line ticket and revoke is nobody's KPI.
2. **Residue on leavers.** SSO deprovisioning kills the federated login. It does not kill non-federated credentials: personal access tokens, service-account keys the person minted, OAuth app grants, webhook secrets, in-app API keys. These survive the offboarding checklist.

1.1 Why existing tooling leaves a gap

This is the part a judge will probe, so state it precisely rather than claiming the category is empty.

Identity Governance and Administration products (SailPoint, Saviynt, Okta Access Certifications, Microsoft Entra ID Governance) already do periodic access certification. Three gaps remain, and Deadbolt targets exactly those:

- **Granularity.** IGA reconciles *application assignment* ("has Salesforce"). It rarely reconciles *in-application scope* ("has Modify All Data on the Opportunity object"). The risk lives in the scope.
- **Non-federated credentials.** PATs, in-app API keys, and OAuth grants are minted by the user inside the app, never traverse the IdP, and are invisible to SSO deprovisioning.
- **Review economics.** Quarterly certification produces a 400-row spreadsheet sent to a manager who approves all of it in ninety seconds. The bottleneck is not detection; it is the cost of a human decision. Deadbolt attacks that cost by arriving with a specific, evidenced, single-click proposal instead of a list.

Positioning claim to defend on stage: Deadbolt is not a cheaper SailPoint. It is a continuous, evidence-carrying remediation loop that sits below the assignment layer where existing IGA does not reach.

1.2 Who it serves

Persona	Pain today	What Deadbolt gives them
IT / Security admin (primary)	Owns revocation, lacks per-app visibility, blamed after incidents	Ranked drift queue, pre-built reversible remediation plans, audit trail
Engineering manager (approver)	Asked to certify 400 rows they cannot evaluate	One Slack card per finding with usage evidence and a 2-click decision
The employee (subject)	Silently over-privileged; a breach of their account is a breach of the company	Least privilege without a ticket; objection window before anything is cut

2. Goals and non-goals

2.1 Goals

- G1 — Build a canonical entitlement graph across ≥ 4 connected systems, refreshed on a schedule and on HR events.
- G2 — Detect drift deterministically and score it, without an LLM in the decision path.
- G3 — Convert each finding into a reversible, dry-runnable remediation plan.
- G4 — Broker human approval where policy requires it, with escalation and timeout semantics that are safe in both directions.
- G5 — Execute at least one **real** revocation live against AWS IAM during the demo, with rollback demonstrated.

- G6 — Emit an OpenTelemetry trace and an immutable audit record for every decision, including the ones the system declined to act on.

2.2 Non-goals (explicit, for the 8-day window)

- Not building an IdP or replacing SSO.
- Not doing anomaly detection on authentication behavior (no UEBA).
- Not supporting on-prem Active Directory.
- Not writing production connectors for Salesforce or Workday. Those are mocked behind the real interface (§4.3) — and the mocking is disclosed, not hidden.
- Not auto-granting anything, ever. Deadbolt only removes or downgrades.

2.3 Alignment risk against the stated brief

The hackathon problem statement is “*Design for a World in Transformation... a solution that plans, acts, and adapts over time... leaves people genuinely better off.*” An IT governance tool reads as B2B infrastructure, not human transformation. Two judges out of five will feel that mismatch.

Mitigation, and it should be in the first thirty seconds of the pitch: the transformation in question is the **joiner-mover-leaver** lifecycle. Every finding Deadbolt produces is generated by a human’s career changing. The person made better off is the employee whose forgotten admin token becomes the entry point in a breach, and the manager who no longer rubber-stamps a spreadsheet they cannot read. Lead with the person, not the IAM policy.

3. Success metrics

ID	Metric	Definition	Demo target
M1	Drift recall	Seeded drift findings detected / seeded drift findings planted	≥ 95% (19/20 seeded)
M2	False revocation rate	Actions executed against entitlements that were in-policy	0 — non-negotiable
M3	Mean time to revocation	HR event timestamp → executed revocation	< 15 min (auto tier), < 4 h (approval tier)
M4	Approver decision time	Slack card delivered → decision recorded	< 60 s median
M5	Reversibility	Executed actions with a verified successful rollback	100%
M6	Cost	Total AWS spend on the sandbox lease	< US\$8 of the \$20 cap

M2 and M5 are the metrics that actually win this. A governance agent that is 80% accurate is unshippable; one that is 100% reversible is deployable at 80% accuracy. Say that out loud in the pitch.

4. Architecture

4.1 Determinism boundary

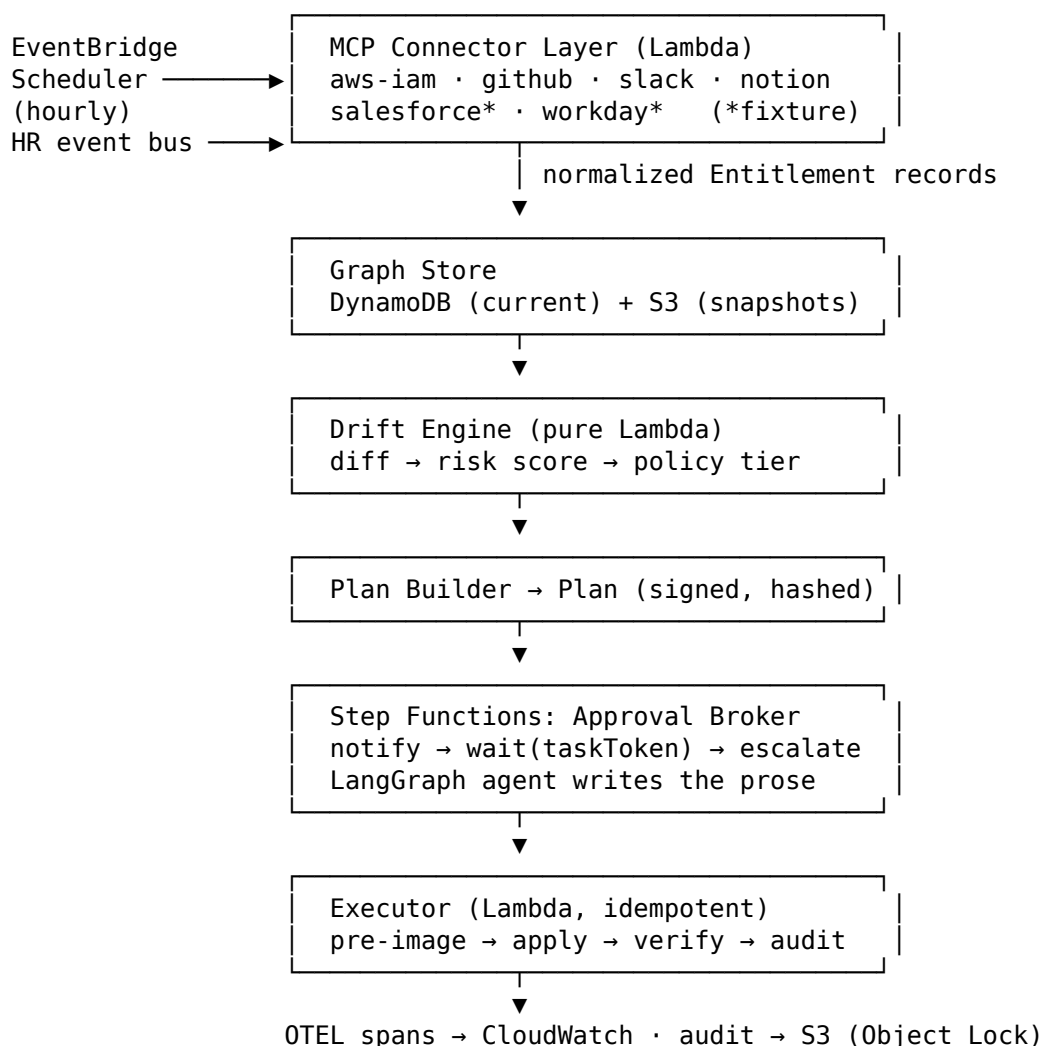
This is the core design decision and the answer to “why not a custom GPT with subagents.”

LLM-authored	Deterministic code
role→entitlement	entitlement graph construction
template proposal	drift diff
negotiation prose	risk scoring
justification text	policy tier selection
summarization	plan generation
	execution
	rollback

The model never decides whether to revoke. It proposes a *role template* (once, offline, human-approved into a versioned store) and it writes *prose*. Every value that gates an action comes from a pure function over the entitlement graph. Given the same graph, Deadbolt produces byte-identical plans across runs — which is the property a custom GPT with subagents cannot offer, and the property a security team requires before granting write scope to anything.

Corollary for the demo: run the drift engine twice on stage and show identical plan hashes.

4.2 Component diagram



4.3 Connector strategy

Split the connector set and be transparent about the split. Judges reward an honest seam; they punish a discovered fake.

Tier A — real APIs, real credentials, free tier, live in the demo:

System	Read surface	Write surface	Notes
AWS IAM (the sandbox account itself)	ListUsers, ListAttachedUserPolicies, GetServiceLastAccessedDetails	DetachUserPolicy, PutUserPolicy	The credibility anchor. IAM Access Advisor gives genuine last-used timestamps — real dormancy data, zero cost.
GitHub (free org)	GET /orgs/{org}/members, /repos/{repo}/collaborators, /user on PAT	DELETE /re- pos/{owner}/{repo}/collaborators/{username}	Fine-grained PAT metadata (scope + last-used).
Slack (free workspace)	users.list, team.integrationLogs	apps.uninstall (scoped)	Doubles as the approval channel.
Notion (free workspace)	/v1/users	manual downgrade	Thin, but a 4th real system.

Tier B — fixture providers implementing the identical interface:

Salesforce and Workday are served by a Lambda that implements the same EntitlementProvider contract against a seeded deterministic fixture. The demo states this in one sentence on a slide. The point is that swapping in the real connector changes one config line and zero engine code — show the interface definition to prove it.

Interface (all six providers implement this):

```

from typing import Protocol, Iterable
from dataclasses import dataclass
from datetime import datetime

@dataclass(frozen=True, slots=True)
class Entitlement:
    identity_id: str          # canonical, resolved via email
    system: str               # "aws-iam" | "github" | ...
    resource: str             # "arn:aws:iam::...:policy/X" | "org/repo"
    scope: str                # "admin" | "write" | "read" | "billing"
    granted_at: datetime | None
    last_used_at: datetime | None # None = never observed used
    credential_type: str      # "federated" | "pat" | "oauth" | "api-key"
    revocable: bool
    raw: dict                 # provider payload, for the audit record

class EntitlementProvider(Protocol):
    system: str
    def snapshot(self) -> Iterable[Entitlement]: ...
    def revoke(self, e: Entitlement, dry_run: bool) -> "ActionResult": ...
    def restore(self, pre_image: dict) -> "ActionResult": ...

```

restore is mandatory on the interface. A provider that cannot restore cannot be onboarded — that is what makes M5 structural rather than aspirational.

4.4 Data model (DynamoDB single table, on-demand)

Item	PK	SK	Purpose
Entitlement	ID#{identity_id}	ENT#{system}#{resource}#{scope}	Current state
Identity	ID#{identity_id}	META	Title, manager, department, status, protected flags
Role template	ROLE#{title_slug}	V#{version}	Approved entitlement set for a title
Finding	FIND#{finding_id}	META	Drift record + score + tier
Plan	PLAN#{plan_id}	ACT#{seq}	Ordered actions, pre-images, hashes
Idempotency	IDEMP#{action_hash}	LOCK	Conditional-write guard on execute

GS11: PK=RES#{system}#{resource}, SK=ID#{identity_id} — answers “who else can reach this resource,” which feeds the blast-radius term.

4.5 Risk scoring

Pure function, no model call, unit-testable:

$$R = 100 \cdot (0.40 S + 0.25 D + 0.20 M + 0.15 B)$$

- **S — scope severity**, from a static catalog: read 0.1, write 0.5, admin 0.9, billing|secrets|iam 1.0.
- **D — dormancy**, $D = \text{clamp}\left(\frac{t_{\text{now}} - t_{\text{last_used}}}{90 \text{ days}}, 0, 1\right)$. Never-used entitlements take $D = 1$.
- **M — role mismatch**, 1 if the entitlement is absent from the approved template for the identity’s current title, else 0. Binary and deterministic; the template itself was LLM-proposed but human-ratified and versioned.
- **B — blast radius**, $B = \text{clamp}\left(\frac{\log_{10}(1 + n_{\text{reachable}})}{4}, 0, 1\right)$, where $n_{\text{reachable}}$ is the count of distinct resources the scope transitively grants access to.

Weights live in a config item, not in code, so the demo can show a security admin retuning policy without a redeploy.

4.6 Policy tiers and the safety asymmetry

Tier	Range	Action on timeout	Executes automatically?
T0 Observe	$R < 30$	—	No. Logged only.
T1 Auto-downgrade	$30 \leq R < 60$	Proceeds after 72 h objection window	Yes, reversible, subject notified at $t=0$
T2 Broker	$60 \leq R < 85$	No action ; escalates to security admin at 24 h	No
T3 Page	$R \geq 85$	No action ; immediate page, plan pre-staged	No

The asymmetry to defend: timeout at T1 proceeds because the action is low-severity and reversible; timeout at T2/T3 does *nothing* because silently cutting an unresponsive manager's report off from a production system during an incident is a worse outcome than one more day of drift. Availability failures caused by a security tool are how security tools get uninstalled.

Break-glass exclusions. Any identity carrying `oncall=true`, membership in a protected group, or an active incident tag is excluded from T1 auto-action entirely and routed to T2. Hard-coded, not scored.

4.7 Approval brokering (“the negotiator”)

Rename the mechanics even if the pitch keeps the word. “Negotiator” suggests the model bargains its way to a decision, which is the exact property a security reviewer will reject. What actually happens:

1. Broker delivers a Slack Block Kit card: identity, entitlement, evidence (last used 147 days ago; not in the Engineering Manager template v4; grants reach to 31 repos), and the proposed action.
2. Approver picks one of four: **Approve** · **Reduce further** (agent counter-proposes a tighter scope) · **Keep, with reason** (free text; recorded and fed back as a template amendment candidate) · **Defer 30 days**.
3. Only “Reduce further” and “Keep, with reason” invoke the LLM — to re-plan a tighter scope from the graph, or to draft the template-amendment proposal. Neither path can widen access.
4. Every branch writes an audit record including the approver identity, the plan hash, and the trace ID.

Step Functions holds the `taskToken` across the wait. `.waitForTaskToken` with a heartbeat is the right primitive here; do not poll.

4.8 Execution and rollback

Executor invariants, in order:

1. Conditional-write the idempotency lock on `sha256(plan_id || action_seq || resource || scope)`. Duplicate delivery is a no-op.
2. Capture the **pre-image** (full prior policy document / collaborator permission) to versioned S3. No pre-image, no execution.
3. Dry-run against the provider. AWS IAM policy simulation via `SimulatePrincipalPolicy` where applicable.
4. Apply.
5. Verify by re-reading the live entitlement and asserting the expected post-state.
6. Write the audit record to S3 with Object Lock in compliance mode (governance mode is enough for the sandbox; note the production choice).

Rollback is `restore(pre_image)` plus verification. The demo must execute a real revocation on AWS IAM, show the access failure, roll it back, and show access restored. That thirty-second sequence is the whole pitch.

5. Tech stack and cost model

5.1 Services

Layer	Choice	Cost posture
Reasoning	Amazon Bedrock, on-demand. Nova Lite for classification/summarization, Claude Haiku for negotiation prose and template proposal	Pay-per-token, no floor
Agent harness	LangGraph in Lambda; AgentCore Runtime only if time permits	LangGraph-in-Lambda has no idle cost
Orchestration	Step Functions Standard (needs <code>waitForTaskToken</code> , which Express lacks)	~\$0.025 per 1k transitions
Compute	Lambda + Function URLs. No API Gateway, no ALB, no VPC	Free tier covers the demo
State	DynamoDB on-demand	Cents
Objects	S3 (snapshots, pre-images, audit) + S3 Vectors if a policy-corpus RAG is added	Cents
Scheduling	EventBridge Scheduler + custom bus for HR events	Negligible

Layer	Choice	Cost posture
Secrets	SSM Parameter Store SecureString , not Secrets Manager	Standard tier is free; Secrets Manager is ~\$0.40/secret/month — six connectors would burn ~\$2.40 for nothing
Observability	ADOT Lambda layer → OTEL → CloudWatch	Watch log retention; set 1 day
Frontend	Static SPA on S3, AG-UI protocol for the agent surface. No CloudFront unless a custom domain is needed	Free

5.2 Budget

Hard cap is US\$20; access is revoked at \$20 and the account is terminated at \$30. The LLM is not the risk. Idle infrastructure is.

Token estimate: 200 identities × ~6 model calls × ~3k input / ~400 output tokens ≈ 3.6M input, 0.5M output per full cycle. At Nova Lite rates that is well under a dollar per cycle; at Haiku rates, a few dollars. **Verify current per-token pricing before the first full run** — model pricing changes and the figures above should not be trusted without a check.

Planned spend: **under \$8**, leaving 60% headroom for a failed experiment.

Prohibited in this project, per the sandbox guidance and basic arithmetic: OpenSearch (hundreds/month floor), SageMaker real-time endpoints (billed hourly at zero traffic), NAT Gateway (~\$1/day), ALB/NLB (~\$0.50/day), any EC2 or RDS, Bedrock Provisioned Throughput.

Region is **us-east-1**. Bedrock access-denied errors are almost always a wrong-region symptom.

5.3 Cost guardrail to build on day 1

A budget-guard Lambda on a 6-hour EventBridge schedule that queries Cost Explorer and posts to Slack when spend crosses \$5, \$10, \$14. Sandbox budget reporting lags by hours, so do not rely on the portal bar alone. Two hours of work that protects the entire project.

6. Scope for the 8-day window

Today is 30 Aug. Submission is 7 Sep. That is 8 calendar days, overlapping the 24 Aug and 25 Aug sessions already past and any remaining mentoring.

MUST (submission fails without these)

1. AWS IAM connector, read + revoke + restore, against the team's own sandbox account.
2. GitHub connector, read + revoke + restore.
3. Two fixture providers (Salesforce, Workday) behind the same interface.
4. Entitlement graph in DynamoDB; hourly snapshot; HR-event-triggered refresh.
5. Drift engine with the scoring function and policy tiers, fully unit-tested.
6. Plan builder with pre-image capture and plan hashing.
7. Slack approval card with the four-way decision and Step Functions taskToken wait.
8. Executor with idempotency, dry-run, verify, rollback.
9. Audit log to S3 + OTEL traces visible in CloudWatch.
10. Seeded scenario: one mover, one leaver, 20 planted drift findings.
11. Demo video and README.

SHOULD

12. Notion + Slack connectors (the 3rd and 4th real systems).
13. AG-UI dashboard: ranked finding queue, graph view, plan diff, one-click rollback.
14. LLM-proposed role templates with a human ratification screen.
15. Blast-radius computation via GSI1.

WON'T (this cycle)

- AgentCore Runtime migration.
- Real Salesforce/Workday connectors.
- Multi-tenant support.
- Anything requiring a VPC.

Day plan

Date	Deliverable
30 Aug	Repo scaffold, EntitlementProvider contract, budget-guard Lambda, DynamoDB table, CDK/SAM deploy working end-to-end with one stub provider
31 Aug	AWS IAM connector (read + Access Advisor last-used), GitHub connector read path
1 Sep	Drift engine + scoring + tiers, unit tests, fixture providers
2 Sep	Plan builder, pre-image capture, executor with dry-run and rollback; first real IAM revoke + restore
3 Sep	Step Functions approval broker, Slack card, LangGraph negotiation node
4 Sep	OTEL wiring, audit log, seeded scenario, end-to-end run
5 Sep	AG-UI dashboard, Notion/Slack connectors if time allows
6 Sep	Demo video, README, architecture diagram, freeze code
7 Sep	Buffer + submission

Days 2 Sep and 6 Sep are the two that cannot slip. If 2 Sep slips, cut the dashboard. If anything else slips, cut connectors — four systems with a real revoke beats six with none.

7. Demo script (5 minutes)

1. **0:00** — A person, not a diagram. “Priya moved from engineer to manager in March. Here is what she still has.” One screen, one number: 23 entitlements, 14 unused for over 90 days, 3 admin-level.
2. **0:45** — Trigger the HR event live. Watch the graph refresh and findings populate, ranked.
3. **1:30** — Open the top finding. Show the evidence: last used 147 days ago, absent from the ratified template, reaches 31 repos. Show the score decomposition, not just the number.
4. **2:15** — Slack card fires. Approver clicks **Reduce further**. Agent counter-proposes read instead of admin, with the reasoning. Approve.
5. **3:00** — Execute against real AWS IAM. Show the access denial in a terminal. Then roll back and show it restored. This is the moment.
6. **4:00** — Re-run the drift engine and show the identical plan hash. “Same input, same plan, every time. That is why this can hold write credentials and a chat agent cannot.”
7. **4:30** — Audit trail and the OTEL trace. Close on the cost line: full run, under \$8.

8. Risks

#	Risk	Likelihood	Impact	Mitigation
R1	Budget exhaustion revokes account mid-build	Med	Fatal	Budget-guard on day 1; no VPC/NAT/ALB/EC2; Parameter Store over Secrets Manager
R2	Judges read Tier B fixtures as a fake demo	Med	High	Disclose on a slide; show the shared interface; anchor on a real IAM revoke
R3	“This is just SailPoint”	Med	High	\$1.1 wedge: sub-assignment granularity, non-federated credentials, per-decision economics
R4	“This is a custom GPT with subagents”	High	High	\$4.1 determinism boundary; identical plan hashes demonstrated live
R5	Brief-alignment mismatch (B2B tool vs. human transformation)	Med	Med	Open on the person; frame as the joiner-mover-leaver lifecycle
R6	GitHub/Slack free-tier API limits or missing endpoints	Med	Med	Verify every endpoint on day 1 before committing; degrade to fixture if a write path is unavailable, and say so
R7	Live demo executes a revoke that cannot be restored	Low	Fatal	restore() mandatory on the interface; rehearse the rollback ≥ 10 times; keep a second sandbox IAM user as fallback

#	Risk	Likelihood	Impact	Mitigation
R8	Team parallelization stalls on the shared interface	Med	Med	Freeze EntitlementProvider by end of 30 Aug; everything else codes against it

9. Open questions

1. Team size and split — who owns connectors vs. engine vs. frontend? Assign before the interface freeze on 30 Aug.
2. Does the sandbox lease permit creating additional IAM users for the demo scenario, or does the lease permission boundary block `iam:CreateUser`? **Verify on day 1** — the entire demo depends on it. Fallback: operate on IAM roles and inline policies within the existing user.
3. Slack free-workspace admin rights for `apps.uninstall` — confirm or downgrade Slack to read-only.
4. Is a policy-document RAG over an internal least-privilege standard worth the S3 Vectors integration, or is it scope creep? Default answer: scope creep. Revisit only if MUST items complete by 4 Sep.